HAICHAIN

INFORME DE DILIGENCIA DEBIDA DE RIESGOS V1.1 • ESTÁNDAR DE DEFENSA CRIPTOGRÁFICA

HAICHAIN: Informe de Diligencia Debida de Riesgos Institucionales

Demostraciones Matemáticas, Modelado de Amenazas y Matriz de Verificación Red-Team para Asignadores Tier-1

AUDIENCIA OBJETIVO	SEGURIDAD CRIPTOGRÁFICA	NÚCLEO DEL PROTOCOLO
Fondos Tier-1 y Firmas Auditoras	Passkey de Hardware • 9 Invariantes	HAICHAIN v1.1 • CapLeaf 223 Bytes

INFORME DE DILIGENCIA DEBIDA DE RIESGOS INSTITUCIONALES DE HAICHAIN

Demostraciones Matemáticas, Modelado de Amenazas y Matriz de Verificación Red-Team

Audiencia Objetivo: Firmas de Capital de Riesgo Tier-1 (a16z crypto, Paradigm, Sequoia), Custodios Institucionales y Firmas Auditoras de Primer Nivel (OtterSec, Neodyme, Kudelski Security)
Versión del Protocolo: HAICHAIN Kernel v1.1 / CapLeaf v1 (Esquema Wire de 223 Bytes)
Estándares: Anchor Framework (Solana L1) + Sui Move (`AgentCap`) + Solver de Intenciones Tron Rail

1. RESUMEN EJECUTIVO Y PARADIGMA DE SEGURIDAD

Los agentes autónomos de IA que ejecutan microtransacciones financieras presentan vectores de ataque radicalmente distintos a las finanzas descentralizadas tradicionales: 1. **Latencia Cero Sin Intervención Humana:** Un agente de IA que realiza llamadas a herramientas puede verse coaccionado mediante Inyección Indirecta de Prompt para emitir miles de vales de pago no autorizados en segundos. 2. **Vulnerabilidad de Filtración de Claves:** Ejecutar instancias de agentes en nodos distribuidos (Cloudflare Workers, MCPs locales, serverless) multiplica el riesgo de exfiltración de claves privadas. 3. **Proliferación de Comercios Sybil:** En una red M2M abierta, comerciantes maliciosos pueden registrar infinitos dominios desechables para eludir las limitaciones de tasa.

Para neutralizar esta amenaza sin sacrificar la ejecución en milisegundos, **HAICHAIN desvincula por completo la custodia de la ejecución financiera**: - **Autoridad Soberana Principal:** La llave biométrica de hardware Passkey FIDO2 WebAuthn (P-256) conserva el 100 % de la propiedad inmutable del fondo. - **Autoridad Aislada de Subagentes:** Los pares de claves Ed25519 efímeros se encuentran estrictamente aislados en un Motor de Políticas fuera de proceso, sin acceso a la frase semilla. - **Anclaje Merkle en Cadena:** El esquema de hoja de 223 bytes garantiza 9 invariantes matemáticos inmutables (I_1 ... I_9).

2. MODELO FORMAL DE AMENAZAS Y FÓRMULAS DE LÍMITE DE PÉRDIDAS

2.1. Taxonomía de Superficie de Ataque

Clase de Amenaza	Escenario	Exposición Web3 Convencional	Límite Peor Caso HAICHAIN
T_1 **(Inyección Indirecta)**	LLM engañado para pagar a comercio no autorizado	Vaciado total de la billetera $(100{,}000+)$	**E_{\text{theft}} = 0$** (Bloqueado por lista blanca Merkle)
T_2 **(Colusión de Comercio)**	Comercio legítimo intenta liquidar dos veces	Doble cargo en la cuenta de usuario	$E_{\text{theft}} = 0$ (Restricción Anchor $P_i \le \min(C_i, R_i)$)
T_3 **(Ataque en Dominio de Prueba)**	Subagente intenta agotar fondos en nueva API	Agotamiento progresivo del fondo	$E_{\text{theft}} \le M_{\text{tpl}}$ (Bloqueado por presupuesto padre)
T_4 **(Compromiso Total del Agente)**	Clave privada expuesta + comercio cómplice	Vaciado instantáneo de la totalidad del fondo	$E_{\text{theft}}(\tau) \le \min(B, K, W_p \cdot n(\tau, \omega_p))$

2.2. Teorema 6.1: Límite Superior de Robo en el Peor de los Casos (T_4)

Sea τ la latencia de respuesta total del protocolo desde que se inicia una transacción no autorizada hasta que la orden de congelamiento de emergencia (Panic Freeze) se confirma en cadena:

$$\tau = t_{\text{detect}} + t_{\text{owner}} + t_{\text{land}}$$

donde $t_{\text{detect}} \le 5.0\text{s}, t_{\text{owner}} \le 2.0\text{s}, t_{\text{land}} \le 5.0\text{s}$.

En el escenario extremo de compromiso total de la clave Ed25519 del agente y colusión con un comercio validado en el árbol Merkle, el robo máximo acumulado $E_{\text{theft}}(\tau)$ está acotado por:

$$E_{\text{theft}}(\tau) \le \min(B, \quad K, \quad W_p \cdot n(\tau, \omega_p), \quad \sum_{i:\, m_i \in <i>Ai>} E_i(\tau))$$

Corolario: Para un fondo institucional con $10{,}000$ USDT, un tope por hoja de 50 USDT y un límite de velocidad de 10 USDT / hora, un atacante que comprometa la clave del agente **no podrá sustraer más de** 10 **USDT** antes de la congelación, preservando el **99.9% (**$9{,}990$ **USDT)** de los activos.

3. MATRIZ DE AUDITORÍA Y ENDURECIMIENTO RED-TEAM

Cinco vectores de ataque críticos han sido probados y mitigados en el núcleo:

	Vector de Ataque	Mecanismo de Vulnerabilidad	Invariante Endurecido On-Chain
1	**Doble Reclamación Escrow**	Presentación de múltiples vales acumulativos para exceder reserva	**Liquidación Monótona Inreversible** $P_i \leq \min(C_i, R_i)$: Límite de desembolso sellado
2	**Secuestro de Cuenta ATA**	Redirección de cuenta destino a un tercero malicioso	**Derivación Canónica Estricta** Validación invariable de PDA en Solana L1
3	**Evasión de Panic Freeze**	Canales antiguos intentan liquidar tras la activación de emergencia	**Aislamiento de Época Instantáneo (I_6)** Invalidación total e inmediata de vales en 380ms
4	**Drenaje Lamport Alquiler**	Robo de lamports de alquiler al cerrar un canal	**Reembolso Canónico de Alquiler** Retorno forzoso al 100% al fondo original (`grant_pot`)
5	**Ataque Sybil Micro-Bucles**	Creación de 1.000 sub-hojas para extraer micro-reservas	**Consumo de Presupuesto Padre** `activate_child` descuenta del techo de reserva matriz

4. INFORME DE AUDITORÍA DE LOS 9 INVARIANTES MATEMÁTICOS ($I_1 \dots I_9$)

Todas las instrucciones on-chain en `programs/haichain-core/src/lib.rs` satisfacen los 9 invariantes matemáticos sin excepción:

1. I_1 **(Conservación de Capital):**

$$\text{Vault}_{ATA} + \sum_{\text{channels}} \text{Escrow}_j + \sum \text{Paid}_j + \text{Refunds} = \text{Depósitos Netos}$$

Verificado formalmente mediante `test_invariant_i1_conservation` en la suite de pruebas.

2. I_2 **(Seguridad de Destinatario Canónico):**

$$\texttt{payee_ata} \equiv \texttt{get_associated_token_address}(\text{merchant}, \text{mint})$$

Ejecutado on-chain mediante restricciones Anchor; previene desvíos de tokens a terceros.

3. I_3 **(Tope Presupuestario Inviolable):**

$$\text{consumed} \leq \texttt{max_spend} \quad \wedge \quad \texttt{budget_used} \leq \texttt{budget_total}$$

Verificado antes de cada reserva o liquidación on-chain.

4. I_4 **(Limitador de Velocidad Autónomo):**

$$\texttt{window_used} \leq \texttt{window_cap} \qquad \forall\, t \in [T_0, T_0 + \omega]$$

Previene el vaciado rápido y automatizado del capital.

5. I_5 **(Estrechamiento Monótono de PDA):**

$$\text{Channel PDA} \subseteq \text{Grant PDA} \subseteq \text{Pot PDA}$$

Las instancias hijas jamás pueden expandir los permisos otorgados por la entidad padre.

6. I_6 **(Época de Pánico y Congelación Inmediata):**

$$\texttt{pot.panic_epoch} == \texttt{channel.created_at_epoch} \quad \wedge \quad \neg\, \texttt{pot.frozen}$$

La parada de emergencia invalida inmediatamente todos los vales en circulación.

7. I_7 **(Expiración del Latido de Sesión):**

$$\texttt{current_time} \leq \texttt{valid_until}$$

Las sesiones caducadas o abandonadas no pueden ejecutar nuevas reservas de fondos.

8. I_8 **(Liquidación Monótona y Única):**

$$\text{paid}_{\text{new}} \leq \min(\texttt{cumulative_amount}, \texttt{reserved_amount}) \quad \wedge \quad \text{paid}_{\text{new}} \geq \text{paid}_{\text{old}}$$

Garantiza cero doble gasto entre vales del canal.

9. I_9 **(Aislamiento de Cuentas Anti-Sybil):**

$$\texttt{PDA}(\text{"chan"}, \text{grant}, \texttt{channel_id}) \text{ es único}$$

Una hoja de capacidad se asigna exactamente a una única cuenta on-chain.

---

5. TOKENÓMICA Y CUMPLIMIENTO NORMATIVO

- **Cero Dividendos y Cero Rendimiento Pasivo:** Inmunidad absoluta frente a las pruebas de Howey y la normativa europea MiCA.
- **50% Recompra y Quema (Buyback & Burn):** Quema programática de $HAISI financiada por las tarifas de la red.
- **50% Fondo de Reserva del Protocolo (CHGB):** Respaldo para SLAs de proveedores y liquidación multired.

---

6. CONCLUSIÓN Y ACCESO A LA SALA DE DATOS (DATA ROOM)

HAICHAIN v1.1 establece la primera infraestructura de pago formalmente demostrada y protegida por hardware para la economía de agentes de IA.